

KIKI Agent™

Autonomous LTV Campaign Execution

KIKI Agent™ – GDPR Compliance Framework

Founder: Ariyo Dolapo

Date: 26 July 2026

Status: Confidential — Data Protection Structure

KIKI Agent™ — A STOREGRILL INC LTD Company
Registered in England & Wales

KIKI Agent™ – GDPR Compliance Framework

A STOREGRILL INC LTD Company — Registered in England & Wales

1. Regulatory Context

KIKI Agent processes personal data of data subjects in the UK and European Economic Area as part of its CAPI enrichment and LTV prediction service. The platform receives conversion events from customers' ecommerce systems, enriches them with predicted lifetime value, and forwards the enriched signal to ad platforms.

Under UK GDPR, KIKI Agent acts as a **data processor** for its customers (the data controllers), processing personal data on their behalf and under their instruction.

Applicable Legislation

Regulation	Jurisdiction	Status
UK GDPR (SI 2019/419)	United Kingdom	✓ Active — binding
Data Protection Act 2018	United Kingdom	✓ Active — binding
EU GDPR (Regulation 2016/679)	European Economic Area	✓ Active — binding (via adequacy decision)
PECR (Privacy and Electronic Communications Regulations)	United Kingdom	✓ Active — binding
ePrivacy Directive (Directive 2002/58/EC)	European Economic Area	✓ Active — binding

2. Data Processing Overview

2.1 Personal Data Processed

Data Category	Data Elements	Source	Purpose	Retention
Transaction Data	Order value, currency, product IDs, order timestamp	Customer's ecommerce platform	LTV prediction, signal enrichment	90 days (active), 365 days (anonymised model training)
Customer Identifiers	Email (hashed), phone (hashed), IP address, user agent	Customer's ecommerce platform	Conversion tracking, event deduplication	90 days
Device Data	Browser fingerprint, device type, operating	Customer's ecommerce	Fraud detection, IVT scoring	30 days

Data Category	Data Elements	Source	Purpose	Retention
	system	platform		
Ad Platform Data	Click ID, campaign ID, ad ID, platform user ID	Ad platform CAPI response	Attribution, bid optimisation	90 days
Account Data	Name, email, company, billing info	Account registration	Customer account, billing	Duration of account + 6 years (HMRC)

2.2 Special Category Data

KIKI Agent does **not** intentionally process special category data under Article 9 of UK GDPR (race, ethnicity, political opinions, religious beliefs, trade union membership, genetic data, biometric data, health data, sex life, or sexual orientation).

Customers are contractually prohibited from sending special category data through the KIKI Agent platform.

2.3 Data Subjects

- End customers of KIKI Agent's customers (purchasers of goods/services)
- KIKI Agent's direct customers (account holders, billing contacts)
- Website visitors (dashboard users, marketing site visitors)

3. Lawful Basis for Processing

Processing Activity	Lawful Basis (UK GDPR Art. 6)	Notes
Conversion event receipt and enrichment	Legitimate interests (Art. 6(1)(f))	KIKI's customer (controller) has legitimate interest in ad optimisation. KIKI processes as their processor.
Fraud detection and IVT scoring	Legitimate interests (Art. 6(1)(f))	Prevention of fraudulent transactions and ad fraud
Account management and billing	Contract (Art. 6(1)(b))	Necessary for performance of the SaaS contract
Marketing communications	Consent (Art. 6(1)(a))	Opt-in consent collected at account registration
Compliance with legal obligations	Legal obligation (Art. 6(1)(c))	HMRC retention, ICO obligations, anti-money laundering

4. Data Processor Obligations (Article 28)

4.1 Data Processing Agreement (DPA)

KIKI Agent enters into a DPA with every customer (data controller) before processing any personal data. The DPA covers:

Clause	Detail
Subject matter and duration	CAPI event enrichment and delivery for the duration of the SaaS subscription
Nature and purpose	Enrichment of conversion events with predicted lifetime value for ad platform optimisation
Personal data types	Transaction data, customer identifiers, device data (see §2.1)
Data subject categories	End customers of the controller
Obligations and rights of the controller	Controller retains all rights under UK GDPR
Sub-processors	Azure, Groq, OpenAI, Stripe (listed in Schedule A)
International transfers	Standard Contractual Clauses (SCCs) for transfers to US sub-processors
Technical and organisational measures	See §6
Assistance with data subject rights	See §7
Breach notification	72 hours to controller (see §8)
Deletion/return of data	On termination of service within 30 days

4.2 Sub-Processor List (Schedule A)

Sub-Processor	Service	Data Accessed	Location	Safeguard
Microsoft Azure	Cloud infrastructure, database, storage	All personal data	UK South + West Europe	UK GDPR adequacy + SCCs
Groq Inc	AI inference (fast bidding tier)	Anonymised conversion data	US	SCCs
OpenAI (Microsoft Azure)	AI inference (GPT-4o/mini)	Anonymised conversion data	US (via Azure)	Azure DPA + SCCs
Stripe Inc	Payment processing	Billing information, payment data	US	SCCs + PCI-DSS
SendGrid (Twilio)	Transactional email	Email address, name	US	SCCs

Sub-processor notification: Customers will be notified 30 days before any new sub-processor is engaged. Customers may object within 14 days of notification.

5. Data Subject Rights (Articles 15–22)

KIKI Agent assists its customers (data controllers) in responding to data subject rights requests:

Right	UK GDPR Article	KIKI Agent's Obligation	Response Time
Right to be informed	13–14	Via Privacy Policy and DPA	N/A — on request
Right of access	15	Search and return all data for a data subject	14 days (to controller)
Right to rectification	16	Correct inaccurate data	14 days
Right to erasure	17	Delete all data for a data subject	30 days
Right to restrict processing	18	Restrict processing of specific data subjects	7 days
Right to data portability	20	Export data in machine-readable format	30 days
Right to object	21	Cease processing for direct marketing	7 days

Process: Controller submits request via KIKI Agent's API or support channel. KIKI Agent fulfils within the timeframes above and confirms completion to controller.

6. Technical & Organisational Measures

6.1 Technical Measures

Category	Measure	Standard
Access Control	RBAC with Admin/Operator/Viewer roles. MFA required for all accounts. SSO available (Enterprise).	ISO 27001-aligned
Encryption at Rest	AES-256 for all databases and storage (Azure SSE)	FIPS 140-2
Encryption in Transit	TLS 1.3 minimum. All API endpoints HTTPS. CAPI webhooks enforce HTTPS.	OWASP
Network Security	Private endpoints for database. WAF on dashboard. DDoS protection via Azure.	Azure Defender
Authentication	JWT with 1-hour expiry. Session tokens with refresh. Password hashing with bcrypt (cost factor 12).	OWASP
Audit Logging	All access to personal data logged: who, what, when, from where. Logs immutable, retained 12 months.	SOC 2-aligned
Backup & Recovery	Daily automated backups. 30-day retention. Quarterly DR testing. RTO: 1 hour. RPO: 6 hours.	ISO 27001-aligned
Data Minimisation	Only data necessary for enrichment is collected. Hashing of email and phone before storage.	UK GDPR Art. 5(1)(c)
Pseudonymisation	Customer identifiers hashed before model training. LTV model operates on pseudonymised data.	UK GDPR Art. 5(1)(e)

6.2 Organisational Measures

Measure	Detail
Data Protection Officer	Appointed and registered with ICO. Contact: dpo@kiki.ai
Staff Training	Mandatory annual data protection training for all staff. Induction training on Day 1.
Data Protection by Design	All new features reviewed by DPO before deployment. Privacy impact assessment template embedded in product development lifecycle.
Incident Response Plan	Documented and tested quarterly. Breach notification escalation within 1 hour.
Records of Processing	Maintained and updated quarterly. Available to ICO on request.
Vendor Due Diligence	All sub-processors assessed against UK GDPR requirements before engagement. Annual reassessment.

7. International Transfers (Articles 44–49)

Transfer Path	Mechanism	Status
UK → Azure UK South	No transfer (UK data residency)	✓ Not required
UK → Azure West Europe	UK GDPR Adequacy Decision (EU)	✓ Adequacy
UK → Groq (US)	Standard Contractual Clauses (2021) + Transfer Risk Assessment	✓ Implemented
UK → OpenAI (US via Azure)	Azure DPA + SCCs + Microsoft DPA	✓ Implemented
UK → Stripe (US)	Standard Contractual Clauses (2021)	✓ Implemented

KIKI Agent maintains a Transfer Risk Assessment (TRA) for each third-country transfer, updated annually or on change of law.

8. Data Breach Response (Articles 33–34)

8.1 Breach Detection & Classification

Severity	Definition	Example
Critical	Likely to result in risk to rights and freedoms. Requires ICO notification.	Unauthorised access to production database containing personal data
High	May result in risk to rights and freedoms.	Accidental disclosure of personal data to wrong recipient
Low	Unlikely to result in risk. Documented internally.	Transient exposure via log file with no external access

8.2 Breach Notification Timing

Notification	Recipient	Timing
Internal alert	Security team / DPO	Within 1 hour of discovery
Customer notification	Affected data controllers	Within 24 hours of confirmation
ICO notification	UK ICO	Within 72 hours (Article 33)
Data subject notification	Affected individuals	Without undue delay (Article 34)

8.3 Breach Response Steps

1. **Detect** — Automated monitoring alert or external report
2. **Triage** — DPO assesses severity (15 minutes)
3. **Contain** — Isolate affected systems, revoke access, preserve evidence
4. **Investigate** — Root cause analysis, data scope assessment
5. **Notify** — Affected controllers, ICO, data subjects (as applicable)
6. **Remediate** — Fix vulnerability, update controls, document lessons learned
7. **Report** — Post-incident report to affected controllers within 14 days

9. Data Retention & Deletion

Data Type	Active Retention	Archive	Deletion
Customer conversion events	90 days	90–365 days (anonymised)	After 365 days
Fraud detection logs	30 days	None	After 30 days
Account data	Duration of account	6 years after closure (HMRC)	After 6 years
Audit logs	12 months	12–36 months (compressed)	After 36 months
AI model training data	N/A	Anonymised, aggregated	Never (anonymised)
Backup snapshots	30 days	None	After 30 days

Customer deletion request: Data deleted within 30 days of contract termination or data deletion request. Anonymised model training data is retained as it no longer constitutes personal data (Recital 26).

10. ICO Registration

Field	Detail
Registered name	STOREGRILL INC LTD
Trading as	KIKI Agent
ICO registration number	[Pending — to be applied for within Month 1 of UK entity incorporation]

Field	Detail
Fee payable	£40 (micro-organisation tier — turnover <£632K and <10 staff)
Renewal	Annual (by credit/debit card via ICO portal)

11. Registration & Compliance Timeline

Milestone	Deadline	Responsible
Register KIKI Agent Ltd at Companies House	Week 3	Co-Founder
Register with ICO	Week 4	Co-Founder
Appoint DPO	Week 4	Co-Founder + Founder
Complete Data Protection Impact Assessment (DPIA)	Month 2	Co-Founder + DPO
Finalise Data Processing Agreement template	Month 2	Co-Founder + Solicitor
Finalise Privacy Policy	Month 2	Co-Founder + Solicitor
Secure PI and cyber insurance	Month 1	Co-Founder
Sub-processor due diligence (annual)	Month 12 (ongoing)	DPO
Breach response drill (quarterly)	Month 3, 6, 9, 12	DPO + Engineering
First annual ICO return	12 months from registration	Co-Founder

12. Key Contacts

Role	Responsible	Contact
Data Protection Officer	[To be appointed]	dpo@kiki.ai
Data Protection Representative (EU)	[To be appointed if required]	eu-rep@kiki.ai
ICO Correspondence	UK Co-Founder	[Via Companies House registered address]
Security Incidents	Engineering + DPO	security@kiki.ai

This document is a framework for GDPR compliance. It should be reviewed by a qualified data protection solicitor before implementation. KIKI Agent™ — A STOREGRILL INC LTD Company. Registered in England & Wales.